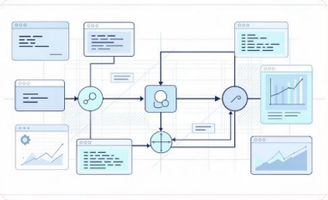
COMPTIA SECAI+ PREP LESSON 2.1.5

Process of AI Threat Modeling

With the foundational prerequisites in place, the next critical phase is to systematically carry out threat modeling for AI systems. This lesson walks through the key steps involved in the process from gathering system context to validating security controls — equipping practitioners with a structured methodology to identify, analyze, and remediate threats specific to AI-powered applications.

Step 1: Gather Prerequisites

Before any analysis can begin, you must build a complete picture of the AI system under review. Gathering the right inputs up front ensures that no critical threat surface is overlooked.

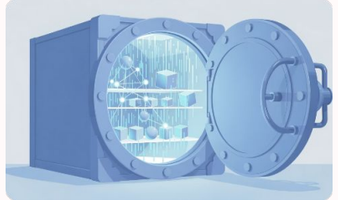


System Context

Collect the business use case, architecture diagrams, data flows, and deployment environment. Understand who will use the system and under what conditions.

Data Inventory

Document what data is used, collected, and processed by the system including inputs, outputs, training data, and any sensitive user-generated content.



Critical Assets

Determine the most important assets at risk: personal data of users, the trained model itself, or the real-world decisions and recommendations the system produces.

Step 2: Choose an AI Threat Modeling Framework

Not all AI threat modeling frameworks are created equal. The right choice depends on your system's architecture, risk profile, and business context. Compile a list of available frameworks and select the one best suited for your use case.

OWASP Top 10

Covers the **LLM Top 10** and **ML Security Top 10** — practical, widely adopted guides to the most critical vulnerabilities in AI and language model deployments.

MITRE ATLAS

The **Adversarial Threat Landscape for AI Systems** — a knowledge base of real-world adversarial tactics, techniques, and case studies targeting machine learning systems.

NIST AI RMF

The **NIST AI Risk Management Framework** provides comprehensive guidance for identifying, assessing, and managing risks across the full AI system lifecycle.

STRIDE / DREAD / MAESTRO

Classic threat-modeling methodologies adapted for AI contexts covering spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege.

Steps 3–4: Identify and Analyze Threats

Step 3: Identify Threats

Adopt an attacker's mindset and enumerate potential threat scenarios:

- Could an attacker update the knowledge base to respond with misleading information?
- Can system instructions be bypassed to jailbreak the model?
- Could the system provide biased or factually incorrect outputs?
- Can the attacker extract or steal the underlying trained model?

Once identified, categorize each threat using the selected AI threat modeling framework.

Step 4: Analyze Threat Severity

With threats catalogued, evaluate each one across two critical dimensions:

Likelihood

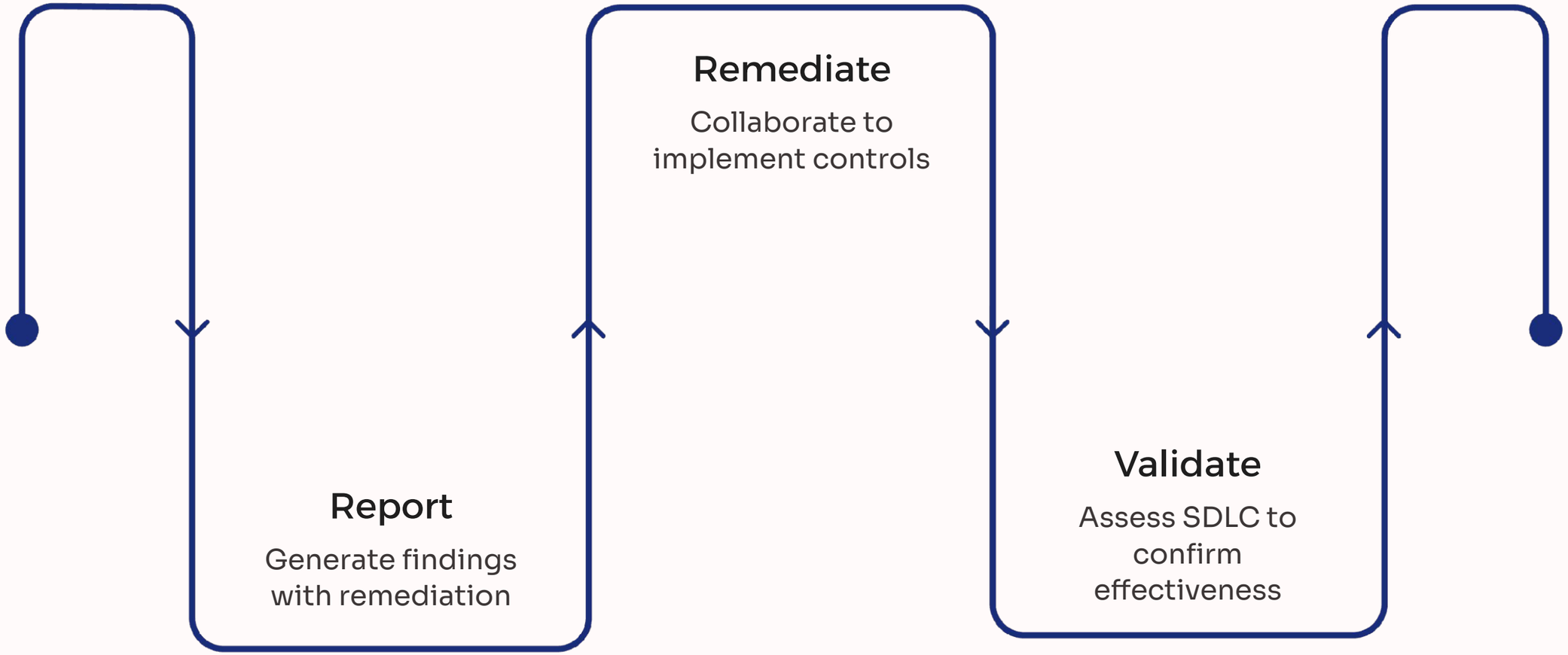
How probable is it that this attack will be attempted and successfully executed in the real world?

Business Impact

What are the consequences if the threat is exploited — data loss, regulatory penalties, reputational damage, or operational disruption?

Steps 5–6: Report, Remediate, and Validate

The final phase transforms threat analysis into actionable outcomes ensuring vulnerabilities are communicated, remediated, and verified across the development lifecycle.



Effective remediation requires close collaboration between security teams, developers, and business stakeholders. Security controls must be validated through formal assessments including penetration testing, red-teaming, and code reviews at multiple checkpoints throughout the **Software Development Life Cycle (SDLC)**. This continuous validation loop ensures that newly introduced vulnerabilities are caught early and mitigated before production deployment.

Analysis of AI Threat Model: Real-World Scenarios

These example scenarios illustrate how abstract threat categories translate into concrete, high-impact risks in a deployed AI application such as a vehicle registration or customer-facing chatbot system.

Scenario 1: Jailbreaking & PII Exposure

An attacker bypasses system instructions to manipulate the bot for personal gain. Without proper access controls, the attacker could access **PII data and car photos** uploaded by other users — a direct breach of confidentiality and data segregation.

Scenario 2: Regulatory & Legal Consequences

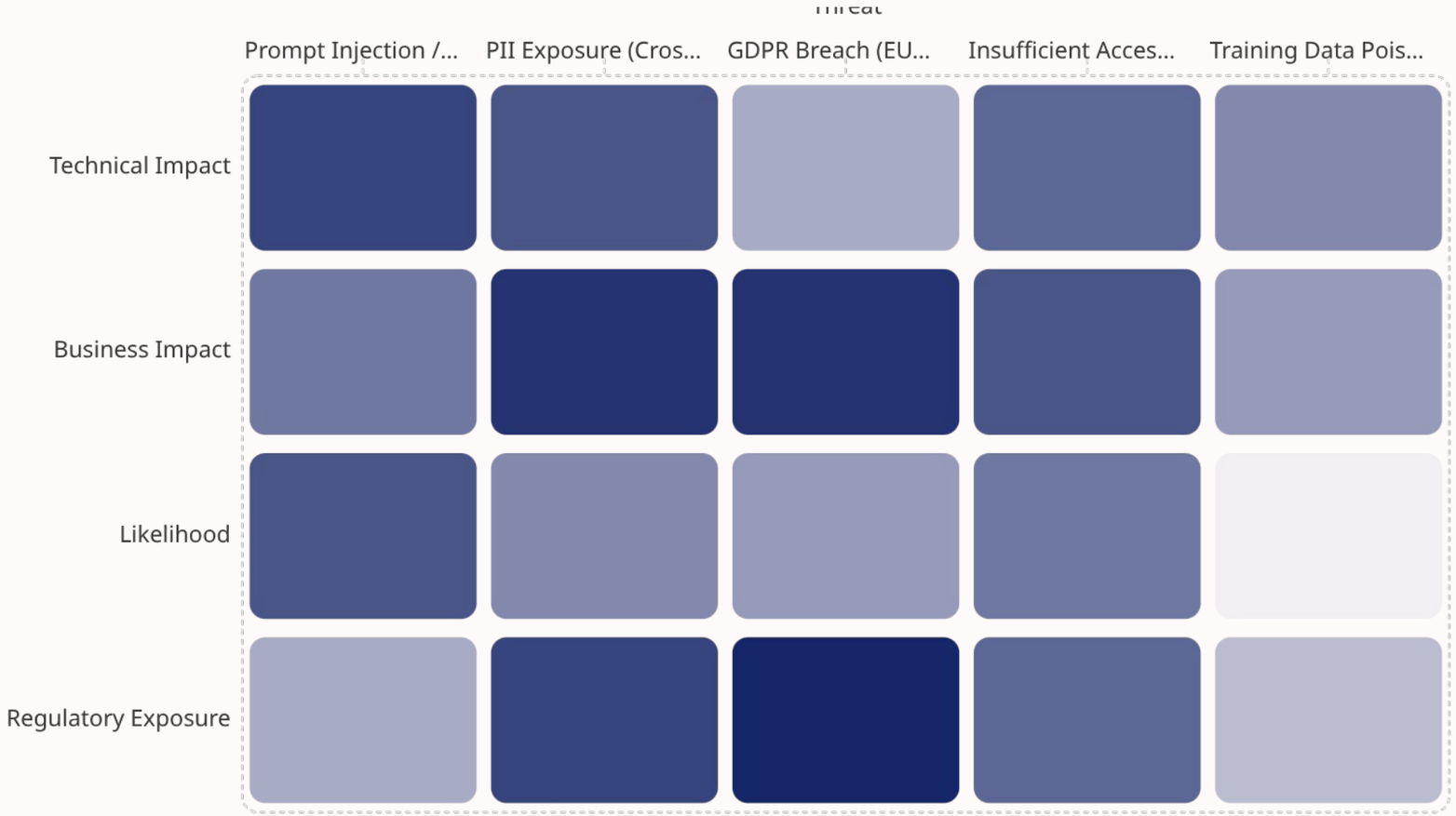
If PII, registration IDs, or car photos of EU-region users are breached, the organization faces **GDPR penalties and legal liability**. Data residency and privacy compliance must be treated as first-class threat vectors, not afterthoughts.

Scenario 3: Recommendations to Prevent Jailbreaking

To prevent prompt injection and jailbreaking attacks, implement **strict access controls** and **parameterized queries**. Avoid giving the AI model direct, unconstrained access to backend systems & enforce least-privilege principles throughout the integration layer.

Threat Scenario Risk Matrix

Mapping the car valuation bot's identified threats across likelihood and impact dimensions helps prioritize remediation effort and justify control investment to stakeholders.



GDPR regulatory exposure and cross-user PII leakage rank highest across combined dimensions — reinforcing that access control and output filtering are the highest-priority controls for this system.

Key Takeaways

The AI threat modeling process provides a structured, repeatable methodology to surface and address risks unique to AI systems from data exposure to adversarial manipulation.

01

Six-Step Process

Gather prerequisites → Choose a framework → Identify threats → Analyze threats → Generate a report → Validate security controls throughout the SDLC.

02

Critical Assets to Protect

Prioritize the personal data of users, the trained model itself, and the real-world decisions it generates. Each represents a distinct threat surface requiring tailored controls.

03

Framework Selection Matters

OWASP Top 10 (LLM & ML), MITRE ATLAS, NIST AI RMF, and STRIDE/DREAD/MAESTRO each serve different analytical needs. Match the framework to your system's risk profile.

04

Severity Rating is Essential

Every identified threat must be rated by **likelihood** and **business impact**. This prioritization drives remediation effort and resource allocation effectively.

05

Real-World Risks: Jailbreaking & Breaches

Jailbreaking, PII data breaches, and EU regulatory penalties are concrete examples of what happens when AI systems lack strict access controls and architectural guardrails.

Security controls must be continuously validated through assessments including red-teaming, penetration testing, and code reviews at every stage of the SDLC to ensure lasting protection.